

CCY2001: Introduction to Cybersecurity

Lecture 3 – Cyberattacks & Vulnerabilities

Dr. Hany Elshall

CCIT

February 22, 2026

Lecture Roadmap

- 1 Introduction to Cyberattacks
- 2 Passive vs. Active Attacks
- 3 Malware Attacks
- 4 Phishing & Social Engineering
- 5 Man-in-the-Middle (MITM) Attacks
- 6 DoS & DDoS Attacks
- 7 SQL Injection
- 8 Brute Force Attacks
- 9 Cryptojacking
- 10 Spam & Cyberstalking
- 11 Defence Strategies Overview
- 12 Summary & Review

What is a Cyberattack?

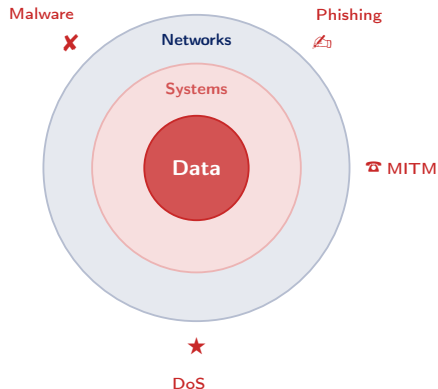
Definition

A **cyberattack** is a malicious attempt to:

- ❖ **Damage** computer systems or networks
- ❖ **Steal** sensitive or confidential data
- ❖ **Gain unauthorised** access to digital resources

Alarming Statistics

- ❖ A hacker attack occurs every **39 seconds**
- ❖ **≈ 2,244 attacks per day** per connected system
- ❖ (*University of Maryland*)
- ❖ Cyber threats are **constantly evolving**



Why Do Attackers Attack?

Financial Gain

Stealing credentials, ransomware extortion, cryptojacking, selling stolen data on the dark web.

Espionage

Gathering corporate or government intelligence, stealing intellectual property and trade secrets.

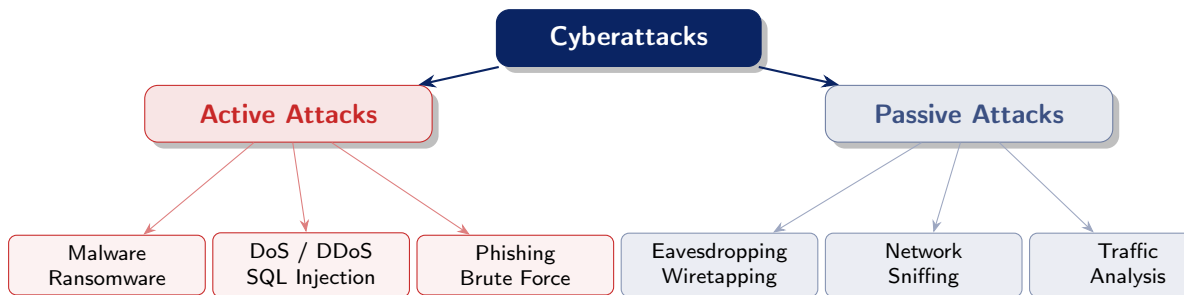
Disruption

Damaging critical infrastructure, hacktivism, DDoS as a protest tool, political motives.

Key Insight

Almost all attackers share one common goal: **gaining access to privileged credentials and accounts** to carry out their ultimate mission.

Two Fundamental Classes of Cyberattacks



Golden Rule

Active attacks **change** the system. Passive attacks only **watch** it. Encryption defeats passive attacks; IDS and firewalls are needed for active attacks.

Passive vs. Active – Key Differences

Active Attacks

- ❖ **Modify**, disrupt, or destroy data/systems
- ❖ Attacker **interacts directly** with the target
- ❖ Cause **visible, direct damage**
- ❖ **Easier to detect** (abnormal behaviour)
- ❖ Harder to prevent fully

Examples:

- ❖ Ransomware encrypting files
- ❖ DDoS flooding a server
- ❖ SQL injection altering a DB
- ❖ Malware deleting data

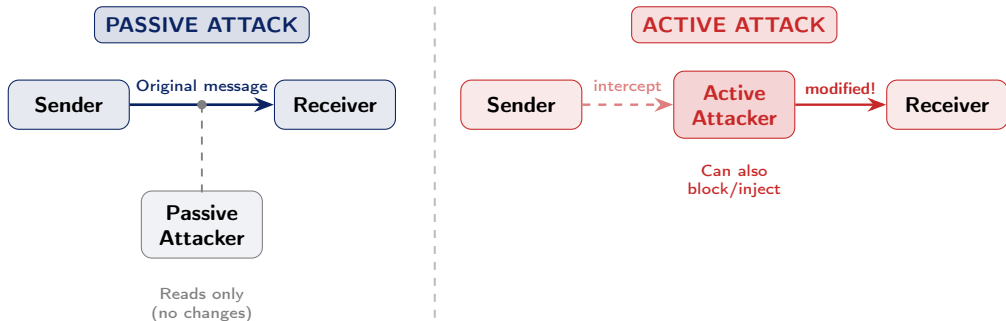
Passive Attacks

- ❖ **Monitor or intercept** data silently
- ❖ Attacker **only observes** – no changes made
- ❖ **No direct modification** of data
- ❖ **Harder to detect** (no visible signs)
- ❖ Easier to prevent with encryption

Examples:

- ❖ Network sniffing capturing passwords
- ❖ Traffic analysis revealing patterns
- ❖ Eavesdropping on public Wi-Fi
- ❖ Wiretapping communications

Passive vs. Active – Visual Diagram



Passive: attacker is invisible – data flows normally, only copied.
Active: attacker intervenes – data is intercepted, modified or blocked.

Malware – What Is It?

Definition

Malware = *Malicious Software*

Any software designed to disrupt, damage, or gain unauthorised access to a system *without the user's knowledge*.

- ❖ Steals personal, financial, and business data
- ❖ Created, sold, and deployed by cybercriminals
- ❖ Delivered via email, websites, USB drives, networks

Attack Type: Active

Malware directly **modifies, encrypts, or destroys** data and system resources. Attackers focus on **gaining privileged credentials**.

Malware Types

- Virus
- Worm
- Trojan
- Spyware
- Adware
- Ransomware

Malware Types – Part 1

Virus

- ❖ Replicates by **infecting other programs**
- ❖ Inserts malicious code into host files
- ❖ Requires user action to spread (opening a file)
- ❖ Difficult to fully remove once active

Worm

- ❖ **Self-replicates without user interaction**
- ❖ Spreads automatically across networks
- ❖ Consumes bandwidth and system resources
- ❖ Example: *ILOVEYOU* (2000) – millions of PCs in hours

Trojan

- ❖ Disguises itself as **legitimate software**
- ❖ Secretly executes harmful actions
- ❖ Can open a “backdoor” for other malware
- ❖ Does **not** self-replicate

Analogy

Like the mythological Trojan Horse – a “gift” that hides a dangerous payload inside.

Virus spreads:



Malware Types – Part 2

Spyware

Silently monitors user activity. Steals passwords, browsing history, and financial data – no visible symptoms.

Adware

Floods users with **unwanted pop-up ads**. Often bundled with free software downloads.

Malvertising

Hides malware inside **legitimate ads**. Simply visiting a trusted site can infect you.

Ransomware – Most Dangerous!

- ❖ **Encrypts** all files on victim's system
- ❖ Demands **ransom** (cryptocurrency) for decryption key
- ❖ Examples: *CryptoLocker*, *Petya*, *Locky*
- ❖ Cost businesses \$20 billion globally in 2021



Malware – Quick Comparison

Type	Spreads How?		Needs User?	Main Goal	Type
Virus	Infects files		Yes (open file)	Corrupt/replicate	Active
Worm	Network	auto-spread	No	Rapid propagation	Active
Trojan	Fake install		Yes (install)	Backdoor access	Active
Spyware	Bundled installs		Sometimes	Steal credentials	Active
Ransomware	Email/download		Yes (open file)	Extort money	Active

Hybrid Malware / Bots

Combines types. Trojan + worm-spread, controlled via a **C&C botnet**.

Phishing Attacks

What is Phishing?

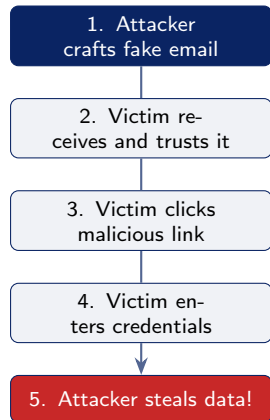
Attackers **trick users** into revealing sensitive information by **impersonating a trusted source**.

Common Delivery Methods

- ❖ Fake emails mimicking banks/government/IT support
- ❖ SMS messages (*smishing*)
- ❖ Fake login pages identical to real ones
- ❖ Phone calls (*vishing*)

Attack Type: Active

Phishing is **Social Engineering**. It actively exploits human psychology to steal credentials or install malware.



Types of Phishing

Generic Phishing

Mass-sent to thousands. Low effort per target, but high volume means high overall impact.

Spear Phishing

Targeted at a specific person. Uses real personal details. Much higher success rate.

Whaling

Targets **top executives** (CEO, CFO). Crafted as urgent legal or board-level notices.



Warning Signs of Phishing Emails

- ❖ Urgent or threatening language; mismatched sender domain
- ❖ Generic greeting ("Dear Customer"); suspicious links
- ❖ Requests for login credentials or personal data

Man-in-the-Middle (MITM) Attacks

Concept

The attacker secretly **intercepts communication** between two parties who believe they are talking directly to each other.

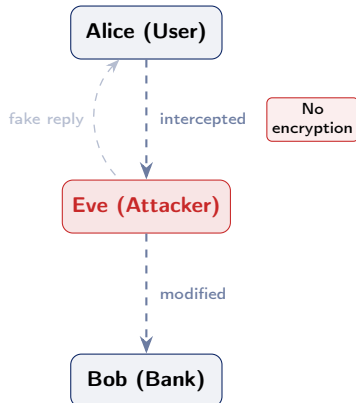
Key Properties

- ❖ Reads, records, and often **modifies** messages
- ❖ Both parties remain **unaware** of the interception
- ❖ Targets: login forms, banking, email

Attack Type: Both (Passive + Active)

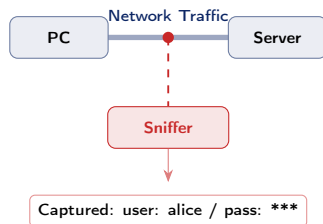
Passive MITM: eavesdrop/sniff only.

Active MITM: modify or inject messages.



MITM Attack – Step by Step

- ❶ **Sniff:** Attacker installs a **network sniffer** to monitor local traffic.
- ❷ **Intercept:** Sniffer captures **unencrypted data** (passwords, tokens).
- ❸ **Identify:** Attacker spots users on public Wi-Fi or HTTP sites.
- ❹ **Redirect:** User is silently sent to a **fake website** cloning the real one.
- ❺ **Harvest:** Victim enters credentials – attacker captures them in real time.



Common Environments

Public Wi-Fi ➤ Unencrypted HTTP ➤ Compromised routers

MITM Attack Techniques

IP Spoofing

Attacker forges the IP address of a trusted source to intercept traffic intended for it.

DNS Spoofing

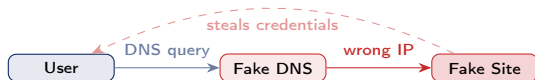
Fake DNS responses redirect users to **malicious websites** that look identical to the real destination.

HTTPS Spoofing

User thinks they are on a secure **HTTPS** page, but they have been silently redirected to plain HTTP – all traffic is exposed.

ARP Spoofing

Attacker sends **fake ARP messages**, linking their MAC address to another device's IP – routing all LAN traffic through them.



DNS Spoofing Attack Flow

Denial of Service (DoS) Attacks

Concept

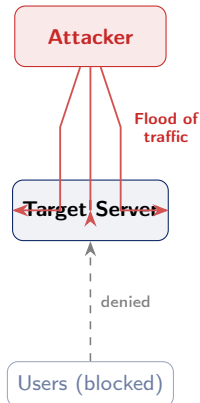
Attacker floods a **target system** with excessive traffic so that **legitimate users can no longer access it**.

How It Works

- ❖ Sends millions of fake requests per second
- ❖ Server CPU, memory, bandwidth are **exhausted**
- ❖ Real users receive **timeouts or errors**

Attack Type: Active

DoS directly **disrupts service availability**. Originates from a **single machine** – easier to detect and block.

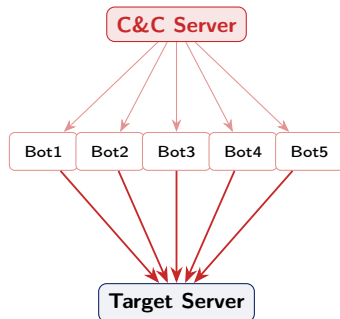


Distributed Denial of Service (DDoS)

What Makes DDoS Different?

Uses a **botnet** – a network of thousands of compromised “zombie” devices – to attack from many locations simultaneously.

- ❖ Controlled via a **Command-and-Control (C&C)** server
- ❖ Your own device may be part of a botnet!
- ❖ Generates **massive** traffic – extremely hard to stop



Real Case: Mirai Botnet (2016)

- ❖ Enslaved **600,000** IoT devices (cameras, DVRs)
- ❖ Launched world's first **1 Terabit/s** DDoS attack
- ❖ Took down **GitHub, Netflix, and Twitter**
- ❖ Created by **three college students!**

DoS vs. DDoS – Comparison

Feature	DoS	DDoS
Attack source	Single machine	Multiple machines (bot-net)
Traffic volume	Moderate	Massive
Detection	Easier (1 IP to block)	Harder (many IPs)
Tracing origin	Straightforward	Very difficult
Speed/damage	Lower	Much higher
Execution	Script/single system	C&C server + botnet

Remember

DDoS $\supset$ DoS – a DDoS attack is essentially **many simultaneous DoS attacks** from many different sources at once. Both are **Active attacks**.

SQL Injection Attacks

What Is It?

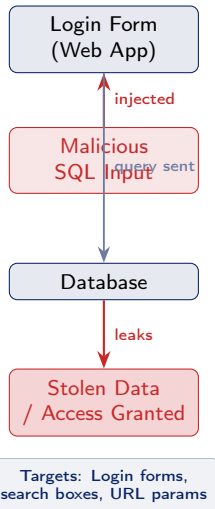
An attacker inserts **malicious SQL code** into an input field to manipulate the backend database.

Goals

- ❖ **Bypass authentication** (login without a real password)
- ❖ **Retrieve** private records (users, credit cards)
- ❖ **Modify or delete** database content
- ❖ Execute **admin commands** on the server

Attack Type: Active

SQL injection directly **modifies application logic and data**. Input is concatenated into SQL without validation.



SQL Injection – How It Works

Normal Login Query

```
SELECT * FROM users
WHERE username='alice'
AND password='secret123';
```

Returns Alice's record if credentials match.

Injected Query

```
-- Attacker types as username:
-- ' OR '1'='1
```

```
SELECT * FROM users
WHERE username='',
OR '1'='1',
AND password='';
```

'1'='1' is always TRUE $\Rightarrow$ login bypassed!

Prevention Strategies

Use **Prepared Statements** (parameterised queries) | Validate & sanitise all inputs | Least-privilege DB accounts | Web Application Firewall (WAF)

Brute Force Attacks

Definition

Automated **trial-and-error** to guess passwords, encryption keys, or credentials until the correct one is found.

How Automated Tools Work

- ❖ Try every possible combination (*pure brute force*)
- ❖ Use **dictionary lists** of common passwords
- ❖ Use leaked databases from past breaches
- ❖ Can attempt **billions** of guesses per second

← 123456 —

← password —

← admin123 —

← qwerty —

Login Portal



Access Granted!

Attack Type: Active

Directly attacks access control. Common targets: login portals, SSH servers, Wi-Fi passwords.

Cryptojacking

What Is It?

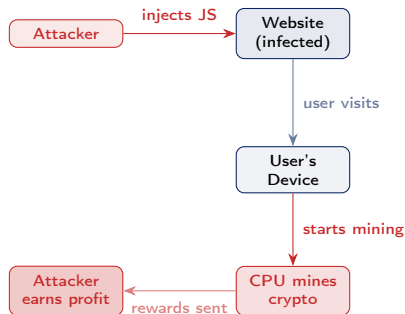
Criminals secretly use **your device's CPU** to mine cryptocurrency – without your knowledge or consent.

Two Main Delivery Methods

- 1 **File-based:** Malware installed via phishing or trojan. Runs a miner in the background.
- 2 **Browser-based:** Hidden JavaScript runs in a webpage. **No installation required!**

Warning Signs

Device very hot | CPU spikes | System sluggish | Battery drains fast



Prevention

Ad-blockers | Anti-cryptomining extensions |
Keep software updated | Antivirus

Spam vs. Phishing

Spam

- ❖ **Unsolicited bulk messages** to many recipients
- ❖ Usually **commercial** (ads, promotions)
- ❖ Not necessarily malicious, but can carry malware
- ❖ Casual tone, random/unfamiliar sender
- ❖ May include fake contests or deals

Remember

Not all spam is phishing, but all phishing uses spam-like delivery.

Phishing

- ❖ **Targeted deception** to steal information
- ❖ Contains a **malicious link** or attachment
- ❖ Formal tone with **urgent/threatening language**
- ❖ Sender address is **spoofed** to appear trusted
- ❖ Threatens consequences (account suspension, etc.)

Cyberstalking

Definition

Cyberstalking is the use of digital technology to repeatedly **harass, threaten, or monitor** a person without their consent.

Common Channels Used

- ❖ Emails and SMS messages
- ❖ Social media platforms
- ❖ Online chat applications
- ❖ Location-tracking apps and spyware

Impact on Victims

- ❖ Severe **emotional distress** and anxiety
- ❖ Persistent **fear** and paranoia
- ❖ **Mental health** deterioration
- ❖ Social isolation
- ❖ In extreme cases: self-harm

Warning Signs:

- Repeated unwanted messages
- Location tracked online
- Harassment across platforms
- Threatening/intimidating tone

Most at Risk

Women and teenagers are the most affected groups. Teenagers are especially vulnerable due to emotional sensitivity and limited online experience.

How to Defend Against Cyberattacks

User-Level Defences

- ❖ Use **strong, unique passwords** + MFA on every account
- ❖ Keep software and OS **updated** to patch vulnerabilities
- ❖ Verify sender before clicking email links
- ❖ Use **HTTPS** sites only for sensitive transactions
- ❖ Avoid public Wi-Fi for banking or shopping
- ❖ Install reputable **antivirus / anti-malware**

System/Network-Level Defences

- ❖ Deploy **firewalls** and intrusion detection (IDS/IPS)
- ❖ Apply **input validation** on all web forms
- ❖ Use **parameterised queries** against SQL injection
- ❖ Implement **rate limiting** to slow brute force
- ❖ Use **DDoS mitigation** services
- ❖ Regular **backups** to recover from ransomware
- ❖ Encrypt all traffic with **VPN** and

Lecture Summary

Attack	Type	Core Mechanism	Key Defence
Malware	Active	Malicious software (virus, worm, ransomware)	Antivirus, backups
Phishing	Active	Social engineering via fake emails	Awareness, verify senders
MITM	Both	Intercept & modify communications	HTTPS, VPN, MFA
DoS/DDoS	Active	Flood target with traffic	Rate limiting, CDN
SQL Injection	Active	Malicious SQL in input fields	Parameterised queries
Brute Force	Active	Trial-and-error password guessing	Strong passwords, lockout
Cryptojacking	Active	Secret crypto mining on device	Browser extensions, AV
Net. Sniffing	Passive	Capture unencrypted traffic	Encryption (HTTP-2, VPN)

Review Questions

Test Your Understanding

- 1 What is the fundamental difference between a **passive** and an **active** cyberattack? Give one example of each.
- 2 What is the difference between a **Virus** and a **Worm**? Which one requires user interaction to spread?
- 3 Explain how a **Man-in-the-Middle** attack works. Is it passive, active, or both?
- 4 Why is a **DDoS** attack harder to defend against than a simple **DoS** attack?
- 5 A login form is vulnerable to SQL Injection. Write an example **injected input** that could bypass authentication.
- 6 A user's laptop runs extremely hot and slowly for no apparent reason. What attack might this indicate, and how can they confirm it?
- 7 List **three differences** between a spam email and a phishing email.



End of Week 03

Cyberattacks and Vulnerabilities

Questions? Visit office hours or post on the course forum.

“The first step in securing a system is understanding how it can be attacked.”

Next Lecture: Network Security Fundamentals